

Day108 代码审计-PHP模型开发篇&MVC层&动态调试未授权&脆弱鉴权&未引用&错误逻辑

代码审计-小迪安全



1.知识点

- 1、PHP审计-原生态开发-SQL注入&语句监控
- 2、PHP审计-原生态开发-SQL注入&正则搜索
- 3、PHP审计-原生态开发-SQL注入&功能追踪

-
- 1、PHP审计-原生态开发-SQL注入&语句监控
 - 2、PHP审计-原生态开发-SQL注入&正则搜索
 - 3、PHP审计-原生态开发-SQL注入&功能追踪

-
- 1、PHP审计-MVC开发-RCE&代码执行
 - 2、PHP审计-MVC开发-RCE&命令执行
 - 3、PHP审计-MVC开发-RCE&文件对比

-
- 1、PHP审计-动态调试-未授权安全
 - 2、PHP审计-文件对比-未授权安全
 - 3、PHP审计-未授权访问-三种形态
-

2.详细点

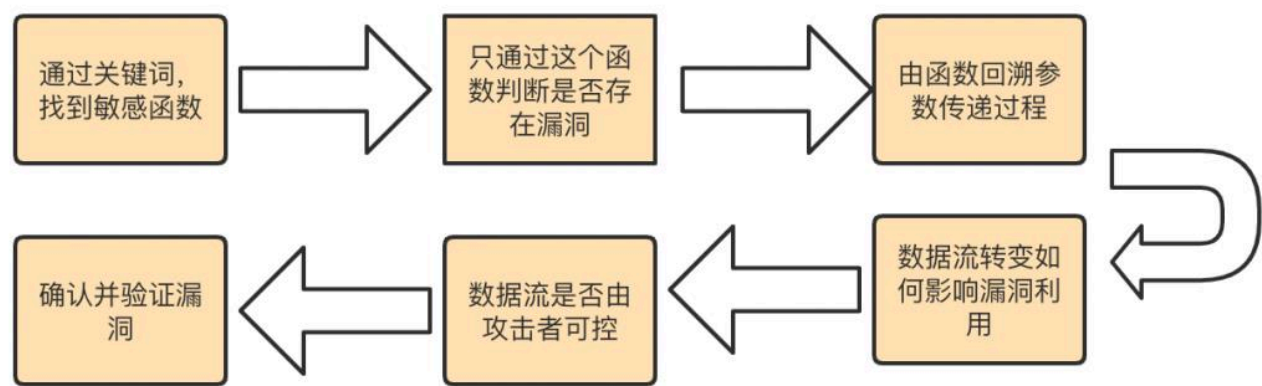
2.1 代码审计分类

- 1、原生态开发-代码审计源码案例
- 2、框架类开发-代码审计源码案例
- 3、组件类开发-代码审计源码案例
- 4、前端类开发-代码审计源码案例

2.2 审计分类

- 1、语言审计-PHP&Net&JS&Java&Python等
 - 2、漏洞审计-注入&RCE&序列化&未授权等
 - 3、框架审计-MVC&Tp&SpringBoot&Flask等
 - 4、组件审计-FastJson&Log4j&Shrio等
 - 5、工具审计-Fortify&Checkmarx&Bandit等
 - 6、技术审计-DAST&SAST&IAST&动态调试等
 - 7、分析审计-CC调用链&内存马原理&JNDI等
-

3.演示案例



函数类型	举例函数或敏感关键词
SQL操作类	Select....., mysql_query...
文件操作类	Move_uploaded_file,copy,/upload/等
命令执行类	System,popen等常见的系统命令做关键词
代码执行类	eval,preg_replace等
引起XSS类	echo等
.....	

功能	出现漏洞类型
文件上传功能	任意文件上传
查询/文章功能	SQL注入
密码找回功能	逻辑漏洞
登陆认证功能	SQL注入，逻辑漏洞
评论功能	XSS漏洞
.....	

MySQL Monitor Client 首页 使用方法 github仓库 博客

MySQL数据库连接参数

127.0.0.1

3306

root

.....

Disconnect

SQL执行记录监控

event_time	user_host	thread_id	server_id	command_type	argument
共 0 条记录					



- 1 -MVC流程:
- 2 1、Controller截获用户发出的请求;
- 3 2、Controller调用Model完成状态的读写操作;
- 4 3、Controller把数据传递给View;
- 5 4、View渲染最终结果并呈献给用户。
- 6 -MVC各层职能:
- 7 1、控制器Controller层-负责响应用户请求、准备数据, 及决定如何展示数据。
- 8 2、模块Model层-管理业务逻辑和数据库逻辑。提供连接和操作数据库的抽象层。
- 9 3、视图View层-负责前端模版渲染数据, 通过HTML方式呈现给用户。
- 10 -MVC对审计主要影响:
- 11 1、文件代码定位问题
- 12 2、代码过滤分析问题
- 13 3、前端安全发现问题



- 1 #PHP常见漏洞关键字:
- 2 SQL注入:
- 3 select insert update mysql_query mysqli等
- 4 文件上传:
- 5 \$_FILES, type="file", 上传, move_uploaded_file()等
- 6 XSS跨站:
- 7 print print_r echo sprintf die var_dump var_export等
- 8 文件包含:
- 9 include include_once require require_once等
- 10 代码执行:
- 11 eval assert preg_replace call_user_func call_user_func_array等
- 12 命令执行:
- 13 system exec shell_exec `` passthru pcntl_exec popen proc_open
- 14 变量覆盖:
- 15 extract() parse_str() importrequestvariables() \$\$ 等
- 16 反序列化:
- 17 serialize() unserialize() __construct __destruct等
- 18 其他漏洞:
- 19 unlink() file_get_contents() show_source() file() fopen()等



- 1 #通用关键字:
- 2 \$_GET, \$_POST, \$_REQUEST, \$_FILES, \$_SERVER等



- 1 MVC开发审计入口常见方法:
- 2 -搜索法: 常规或部分MVC模型源码可以采用关键字的搜索挖掘思路
- 3 -功能法: 框架MVC模型源码一般会采用功能点分析抓包追踪挖掘思路
- 4 -对比法: 可以通过前后修复版本文件及代码不同特征进行针对挖掘思路
- 5 -特征法: 数据库监控挖SQL注入, 文件监控挖上传删除写入等, 后续补充
- 6 -调试法: 动态调试
- 7 -工具法: 后续讲到



- 1 -动态调试优点:
- 2 1、实时跟踪代码执行流程
- 3 2、实时获取变量接受数据
- 4 3、实时分析指定文件动态
- 5 环境配置: https://mp.weixin.qq.com/s/7k8edea8imalz8_jJp30Dw



- 1 -未授权安全挖掘问题
- 2 1、找鉴权看引用-未引用鉴权逻辑
- 3 2、找鉴权看脆弱-脆弱的鉴权逻辑
- 4 3、找鉴权看逻辑-不严谨的鉴权逻辑

3.1 PHP审计-动态调试-脆弱的鉴权逻辑



- 1 #案例1-Xhcms-动态调试-脆弱的鉴权逻辑
- 2 测试: 直接在操作功能下断点发包测试 (已登录)
- 3 找到鉴权文件进行代码分析 (能绕过和不能绕过)

3.2 PHP审计-动态调试-未引用鉴权逻辑



- 1 #案例2-Cwcms-动态调试-未引用鉴权逻辑
- 2 测试: 直接在操作功能下断点发包测试 (未登录)
- 3 断点获取到说明执行有未授权, 获取不到没执行没未授权

3.3 PHP审计-动态调试-不严谨的鉴权逻辑



- 1 #案例3-Bosscms-动态调试-不严谨的鉴权逻辑
- 2 <https://www.cnvd.org.cn/flaw/show/CNVD-2022-19247>
- 3 1、文件对比找入口
- 4 鉴权文件:
- 5 /system/basic/class/admin.class.php
- 6 功能文件:
- 7 /system/admin/safe/backup.class.php
- 8 判断未登录时通过header进行页面跳转,

- 9 但是没有`exit()`或者`die()`终止程序运行
- 10 2、动态调试未授权操作
- 11 直接在操作功能下断点发包测试（已登录和未登录）
- 12 断点获取到说明执行有未授权，获取不到没执行没未授权
- 13 1.1版本-只判断是不是文件，鉴权跳转
- 14 1.3版本-判断文件外加匹配文件名，鉴权跳转加验证

3.4 PHP审计-泛微OA-未授权触发文件上传

- 
- 1 #案例4-泛微eoffice-未授权文件上传
 - 2 <https://xz.aliyun.com/t/10646>
 - 3 <https://www.cnvd.org.cn/flaw/show/CNVD-2021-49104>
 - 4 文件对比：覆盖后无法上传
 - 5 `/general/index/UploadFile.php`
 - 6 `/inc/conn.php`
 - 7 `/inc/oa_config.php`